Car Rental Firm
Security Protocol Project

Group 11

Marcelo Ribero Cerro s1100744 Beatrise Bertule s1105119 Julianne Polman s1173079
Sarah Rahman s1144280

1 Introduction

We have chosen the vehicle rental system as our project. In this document you will find the required documentation about our design.

1.1 Business Model

We shortly define the business model as follows:

The customer signs up for the service online. They will then receive a personalized smart-card containing all the required data for the service. The smart-card is considered issued when related to a customer. With their new smart-card the customer can assign themselves to an available vehicle via the reception terminal. The customer can then use the smart-card to open and start the vehicle. Once the vehicle journey is completed costumer must pay the mileage consumed (this information is in the smart-card). Before assigning themselves to a new vehicle to must pay their outstanding bills.

1.2 System Components

Our business model consists of the following components:

- **Backend system**: Stores and manages information about vehicle availability as well as customer data. It is responsible for coordinating car assignments and supporting the operation of the other system components.
- **Personalization terminal**: Used to personalize a car once it has been assigned to a new customer. During this process, a certificate is generated and signed using the master secret key. This certificate binds the public key of the customer's card, which is embedded within the card, to the assigned vehicle.
- **Reception terminal**: The interface through which customers rent a car. It communicates with the backend system to check vehicle availability and register rentals.

1.3 Smart-Card Lifecycle

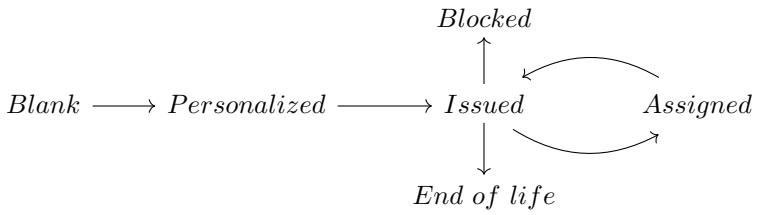


Figure 1: State Transition Diagram for Smart-card Lifecycle

We define six possible smart-card states: (1) Blank, (2) Personalized, (3) Issued, (4) Assigned, (5) Blocked and (6) End-of-life. Both the issued, assigned and blocked state will be tracked by both the backend and the smart-card. You can find an illustration in Figure 1. Below we have a provided a description for each state:

1. **Blank State**.
   The factory default state. The smart-card contains no provider-specific cryptographic keys or user data.

2. **Personalized State**.
   The smart-card has been loaded with the system's cryptographic keys and a unique ID. It is technically ready but not yet linked to a user.
3. **Issued State**.
   The smart-card's ID is linked to a specific customer in the backend database. The issued state is recorded in the backend.It is in circulation and ready for vehicle assignment. This state information is recorded both in the backend and smart-card.
4. **Assigned State**.
   The smart-card has the temporary access credentials required to unlock and start a specific vehicle. This state information is recorded both in the backend and smart-card
5. **Blocked State**.
   A security-revoked state. The smart-card is manually disabled by the backend (e.g., due to theft or loss) and is rejected by all terminals. This state information is recorded both in the backend and smart-card
6. **End-of-life State**.
   A terminal state reached automatically when the smart-card's certificate or physical expiry date passes.

2 Use Case

We have identified the following use cases:

- The customer can register for the service and receive a single personalized smart-card that they can use to access the services offered by the company.
- The smart-card can be personalized in a personalization terminal. This personalization contains crucial information such as cryptographic keys and ID. The personalized smart-card allows for a unique customer be linked to it.
- The smart-card can be blocked in case of loss or theft.
- The smart-card that reaches the end-of-life state should be treated like a blocked smart-card.
- The reception terminals can block/retire a smart-card base on the smart-card ID and the current status of the database.
- The customer can assign themselves to a vehicle at a given time-slot by using a reception terminal and their smart-card.
- The customer can open the vehicle for which their smart-card is assigned to.
- A customer can pay their pending mileage at a reception terminal.
- The smart-cards can always be reassigned to another vehicle if it does not violate any other rules.
- The customer authenticates to the smart-card using a PIN code before performing sensitive operations such as vehicle assignment and payment at a reception terminal.
- The smart-card serves as the ignition key to the vehicle.
- The customer can gracefully retire the smart-card from the onboard terminal and have the travel details correctly saved on the smart-card.

3 Attacker/Threat Model

To define potential threats, we deployed the STRIDE threat model:

1. **Spoofing**:
   - Impersonate a legitimate user by physically stealing the smart card and obtaining the associated PIN.
   - Deploy MitM attack to eavesdrop on communication to steal sensitive information.
   - Impersonate a legitimate terminal to eavesdrop on communication to steal sensitive information.
2. **Tampering**:
   - Modify or inject messages exchanged between smart-card and terminals if cryptographic protection is not enforced.
   - Replay or reuse previously valid messages if freshness guarantees (e.g., nonces) are not properly implemented.
   - Interrupt communication (e.g., removing the smart-card) to cause inconsistent protocol execution.

3. **Repudiation**:
   - A customer may deny having unlocked or used a vehicle.
   - A customer may deny having accumulated certain mileage.
   - A terminal may deny authorizing a vehicle assignment.
   - Disputes may arise if transaction records are not signed and logged securely.
4. **Information Disclosure**:
   - Eavesdrop on communication between smart-card and terminals to obtain identifiers or transaction data.
   - Extract the PIN code from a malicious or compromised terminal.
   - Learn vehicle assignment or customer identity information through unencrypted messages.
5. **Denial of Service**:
   - Rent or reserve all available vehicles simultaneously using protocol abuse.
   - Send malformed or repeated messages to terminals to exhaust resources.
   - Tamper with time-slot or expiration values to lock vehicles indefinitely.
6. **Escalation of Privileges**:
   - Perform unauthorized smart-card state transitions (e.g., from *Issued* to *Assigned* without backend approval).
   - Exploit weak authorization checks to assign multiple vehicles to one smart-card.
   - Attempt to bypass or brute-force the PIN authentication mechanism to gain unauthorized access to smart-card functionality.

3.1 Trusted Computing Base

The Trusted Computing Base (TCB) consists of several components. We assume that the personalization terminal and the reception terminal are trusted. Both terminals will be placed under CCTV surveillance. In addition, the personalization terminal will be monitored by employees and located within a secure facility to reduce the risk of unauthorized access or tampering.

We also fully trust the backend system. The backend will be hosted in a secure facility under CCTV surveillance within a building that is not accessible to customers or unauthorized employees. Due to these physical and organizational security measures, we assume that the personalization terminal, reception terminal, and backend infrastructure cannot be tampered with without detection.

Furthermore, employees are considered part of the Trusted Computing Base. To reinforce this trust, employees will be required to sign a contract that legally obligates them not to damage, tamper with, or manipulate company property, including both physical assets and intellectual property. Employees are also responsible for verifying that the terminals have not been tampered with. However, despite these obligations, there remains a small risk that an employee may intentionally or unintentionally allow someone to perform malicious activities. This risk is mitigated through additional security measures such as surveillance and operational oversight (security staff that oversees employees and system operations to detect and prevent misuse).

3.2 Assumptions

These are the assumptions that we make explicit:

- Every vehicle has a correct and reasonably synchronized clock.
- The customer's driver license and identity have been verified during registration.
- Smart-cards are tamper-resistant and do not leak private cryptographic keys.
- Secure random number generation is available for key and nonce generation.
- There are no malicious insiders among company employees (trusted computing base assumption).
- Customers possess at most one active smart-card at any given time.
- Smart-card's PIN code has brute-force's success rate of $\frac{q}{10^4}$ where q is the amount of tries.

4 Security Requirements

We have identified the following security requirements:

4.1 Authentication Requirements

- **User authentication**: Customers must authenticate themselves to their smart-card using a PIN code before performing sensitive operations such as vehicle assignment and payment.
- **Mutual authentication**: Before any security-sensitive communication:
  - The smart-card and reception terminal must mutually authenticate.
  - The smart-card and vehicle terminal must mutually authenticate.

4.2 Authorization Requirements

1. **Vehicle access control**: A vehicle shall unlock only if:
   (a) The smart-card is assigned to that vehicle;
   (b) The smart-card is not blocked or expired;
   (c) The customer has authenticated successfully.
2. **Time-Slot Enforcement**: At most one customer shall be assigned to a vehicle during a given time-slot.
3. **Payment Enforcement**: A smart-card with unpaid mileage shall not:
   (a) Be reassigned to another vehicle;
   (b) Be used to unlock any vehicle.
4. **State Enforcement**: All smart-card state transitions must be authorized by a legitimate party.

4.3 Integrity Requirements

1. All data stored on the smart-card or exchanged between system components must be protected against unauthorized modification.
2. Any modification of stored data (e.g., mileage, vehicle assignment, lifecycle state) must be detectable.
3. Communication must ensure freshness so that previously valid messages cannot be reused.

4.4 Confidentiality Requirements

1. PIN Protection: The PIN code shall:
   (a) Never leave the smart-card ;
   (b) Be stored within the smart-card as hash;
   (c) Be protected against brute-force attempts (limited retries).

4.5 Non-Repudiation Requirements

TODO: The logging is still a bit vague, but let's fix that after we finished the code

The following systems: reception terminal, vehicle terminal and backend; will keep track of all relevant verifiable communication, this by logging. The following actions must be attributable to a specific entity:

- Vehicle assignment
- Vehicle access (unlock/start)
- Mileage updates
- Payments

The systems (reception terminal, vehicle terminal and backend) must log:

- Successful authentications
- Failed authentication attempts
- Smart-card revocation events
- Vehicle unlock events
- Mileage updates

The logs will be stored, which will contain information about the actions.

4.6 Availability Requirements

1. Lost or stolen smart-cards shall be revocable via backend terminals.
2. The smart-card's PIN code can be verified offline.

4.7 Cryptographic Requirements

1. **Key Separation**: Different cryptographic keys shall be used for:
   (a) Digital signatures;
   (b) Each key-holder must have a different keys (terminals and smart-cards).
2. **Standardized Cryptography**: The cryptographic algorithms should be standardized by NIST.
3. **Certificate Infrastructure**: All terminals and smart-cards shall possess digital certificates issued by the company's Certificate Authority (CA).
4. **Secure Randomness**: All nonces and cryptographic keys must be generated using cryptographically secure random number generators.
5. **Secure Master Key**: The master key that signs terminal public keys shall be guarded by seven angry dogs, two mountain ranges and fire walls.

Pol: or j
the pers
alization
terminal

5 Key and Certificate Distribution

As shown in Table 1, all smart-cards and terminals store the master public key MPK to verify certificates issued by the backend. The master private key MSK is used exclusively for certificate generation and is never shared. Each entity possesses a unique private key, and no private keys are reused across different roles. The persistent counter t stored on the smart-card ensures freshness of messages and prevents replay attacks.

It is important to note that once a smart card is personalized (assigned to a new customer), it is provisioned with a pair of cryptographic keys (pk_c, sk_c). In addition, the smart card receives a certificate C_t that binds its public key pk_c to the system. This certificate is signed using the master secret key MSK.

Entity	**Key/Credential**	**Type**	**Purpose**
Backend (CA)	MSK	Private key	Master key used to issue certificates for smart-cards and terminals
	MPK	Public key	Stored on all devices to verify certificates and signed authorizations
Smart-card	sk_c	Private key	Signs authentication messages and nonces
	pk_c	Public key	Verified by terminals during authentication
	$C_c = \text{Sign}_{MSK}(pk_c)$	Certificate	Proves legitimacy of the smart-card
Reception Terminal	sk_t	Private signing key	Signs rental authorization tokens and transaction approvals
	pk_t	Public key	Verified by smart-cards during mutual authentication
	$C_t = \text{Sign}_{MSK}(pk_t)$	Certificate	Proves legitimacy of the reception terminal
Car Terminal	MPK	Public key	Used to verify backend-issued signatures for offline authentication

Table 1: Key and certificate distribution in the vehicle rental system

6 Security protocols

We divide communication into two parts, communication with the reception terminal (online) and communication with the onboard terminal (offline).

6.1 Personalization Terminal

The personalization terminal is responsible for initializing and configuring smart-cards before they are issued to customers. During this process, the smart-card is provisioned with its unique cryptographic material as defined in Table 1. In particular, the terminal securely generates or installs the key pair (pk_c, sk_c) on the smart-card and ensures that the private key sk_c never leaves the card.

Additionally, the personalization terminal communicates with the backend (CA) to obtain a certificate $C_c = \text{Sign}_{MSK}(pk_c)$, which binds the smart-card's public key to the system. This certificate, along with the master public key MPK, is stored on the smart-card to enable verification of other entities during future interactions.

The personalization process also initializes the persistent counter t, which is used to guarantee freshness of messages and protect against replay attacks. After successful personalization, the smart-card is uniquely associated with a customer and is ready to participate in authentication protocols with reception and onboard terminals.

6.2 Reception Terminal

Before using the services of the reception terminal we must first do mutual authentication of reception terminal, smart-card's user and smart-card. This is shown in Figure 4. It is composed of the following steps.

- Smart-card verifies reception terminal by using a nonce in a challenge and response manner and then verifying its certificate (steps 1-6).
- Smart-card verifies the user via the reception terminal with a PIN (8-10).
- Reception terminal verifies the smart-card by using a nonce in a challenge and response manner and then verifying its certificate (11-16).

After mutual authentication the user can now request a vehicle. This is shown in Figure 5.

- Reception terminal displays vehicles and the user makes a request (steps 1-7).
- The vehicle request is forwarded to the backend for approval and the smart-card stores the approved request (8-13).

6.3 Onboard Terminal

The goal of this communication is to validate the smart-card and the smart-card's approved vehicle request. Shown in Figure 6

- We authenticate smart-card's user with a PIN (steps 1,3).
- We authenticate the smart-card with a nonce (4-10).
- We verify the validity of the request, right smart-card, vehicle, backend and time period. (11-13).

6.4 Mileage Recording Protocol

Figure 2 visualizes the message sequence diagram of mileage update protocol. The mileage recording protocol is executed while the vehicle is in use. The vehicle periodically computes the current mileage and sends it to the smart-card. Each message includes a sequence number to ensure freshness and prevent replay attacks. Upon receiving a mileage update, the smart-card verifies the sequence number and stores the value securely. This process may occur continuously or at specific events such as when the vehicle is stopped or switched off. This ensures that the smart-card maintains a trusted and tamper-resistant record of the traveled distance throughout the rental period.

6.5 Vehicle Return Protocol

Figure 3 visualizes the message sequence diagram of the return of the vehicle. The vehicle return protocol is executed when the rental session ends. The vehicle sends the final mileage value to the smart-card. The smart-card generates a digital signature over the final mileage value to ensure non-repudiation. After this, the smart-card deletes the stored assignment token σ_4 and updates its state from *Assigned* to *Issued*, preventing further access to the vehicle. The signed mileage value is later verified by the backend during the next interaction with a reception terminal.

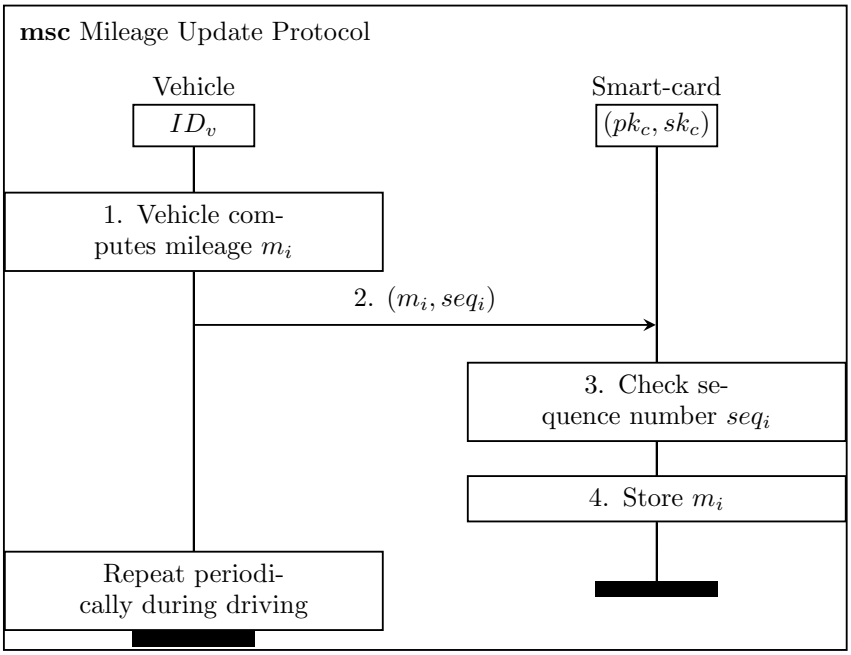


Figure 2: Mileage update protocol during driving

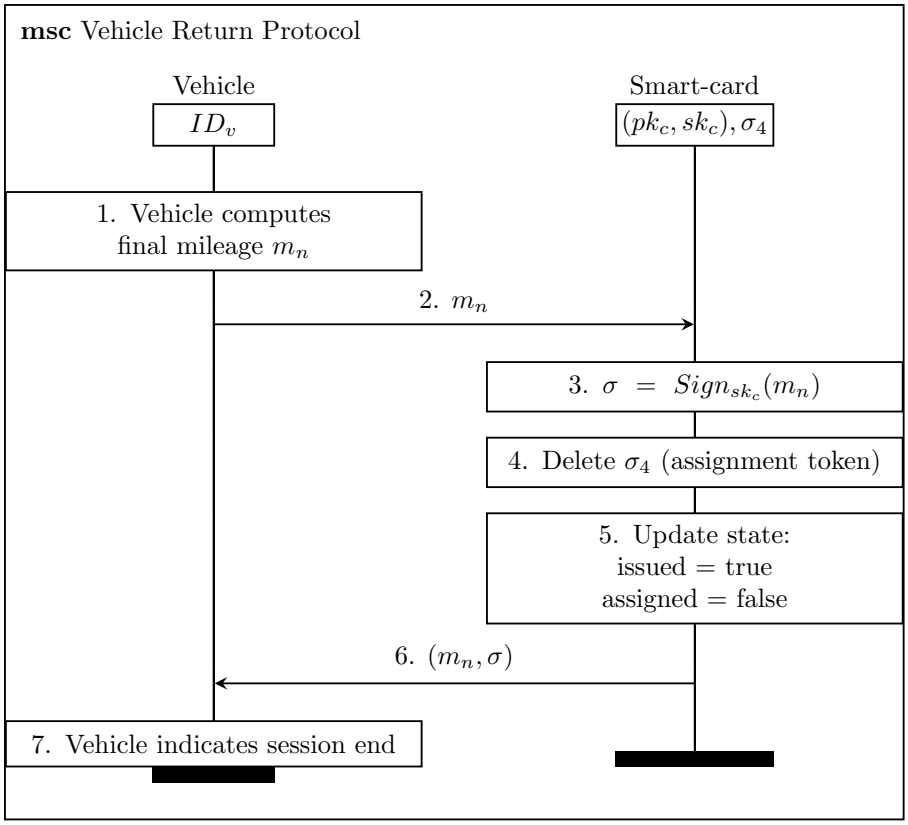


Figure 3: Vehicle return protocol

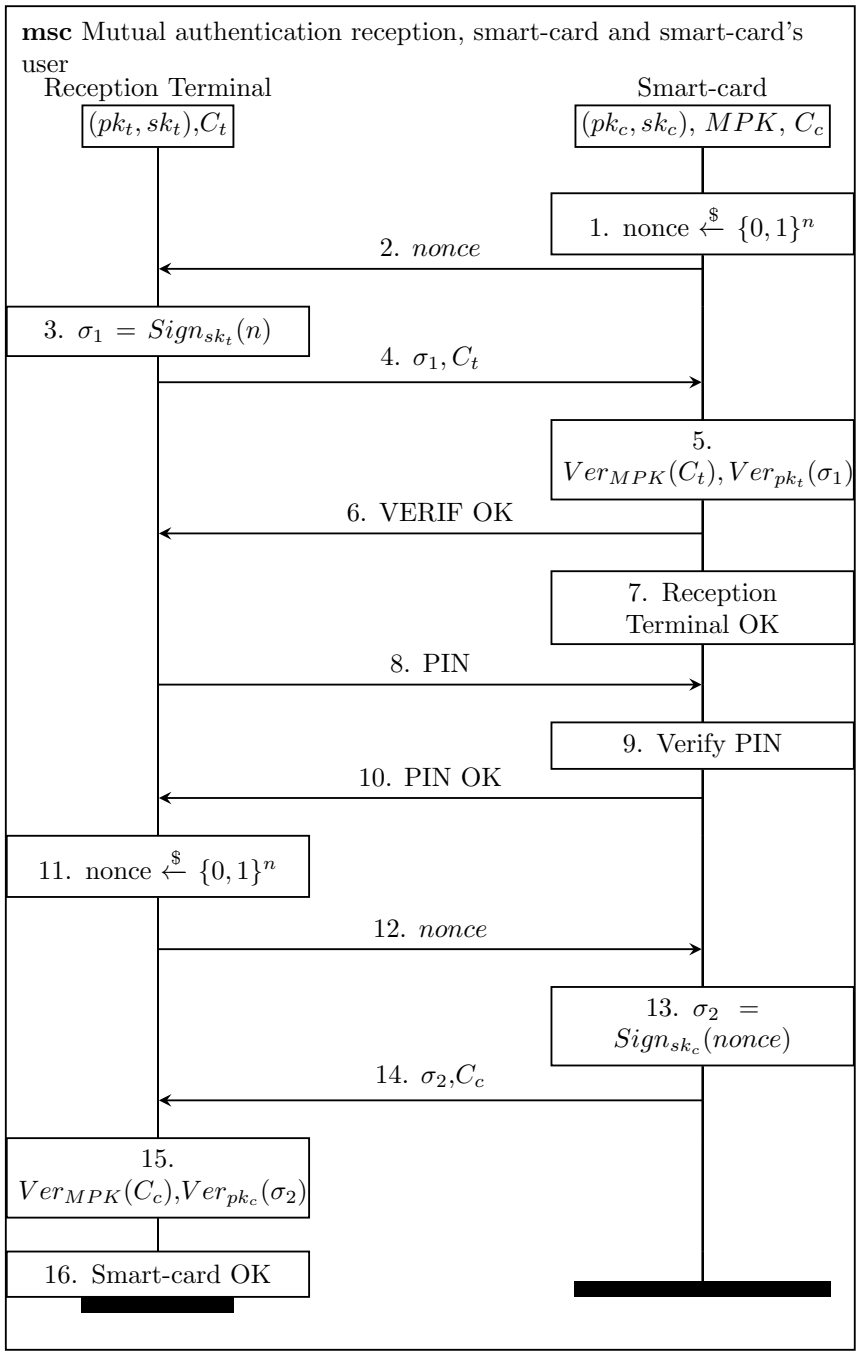


Figure 4: Mutual authentication reception, smart-card and smart-card's user

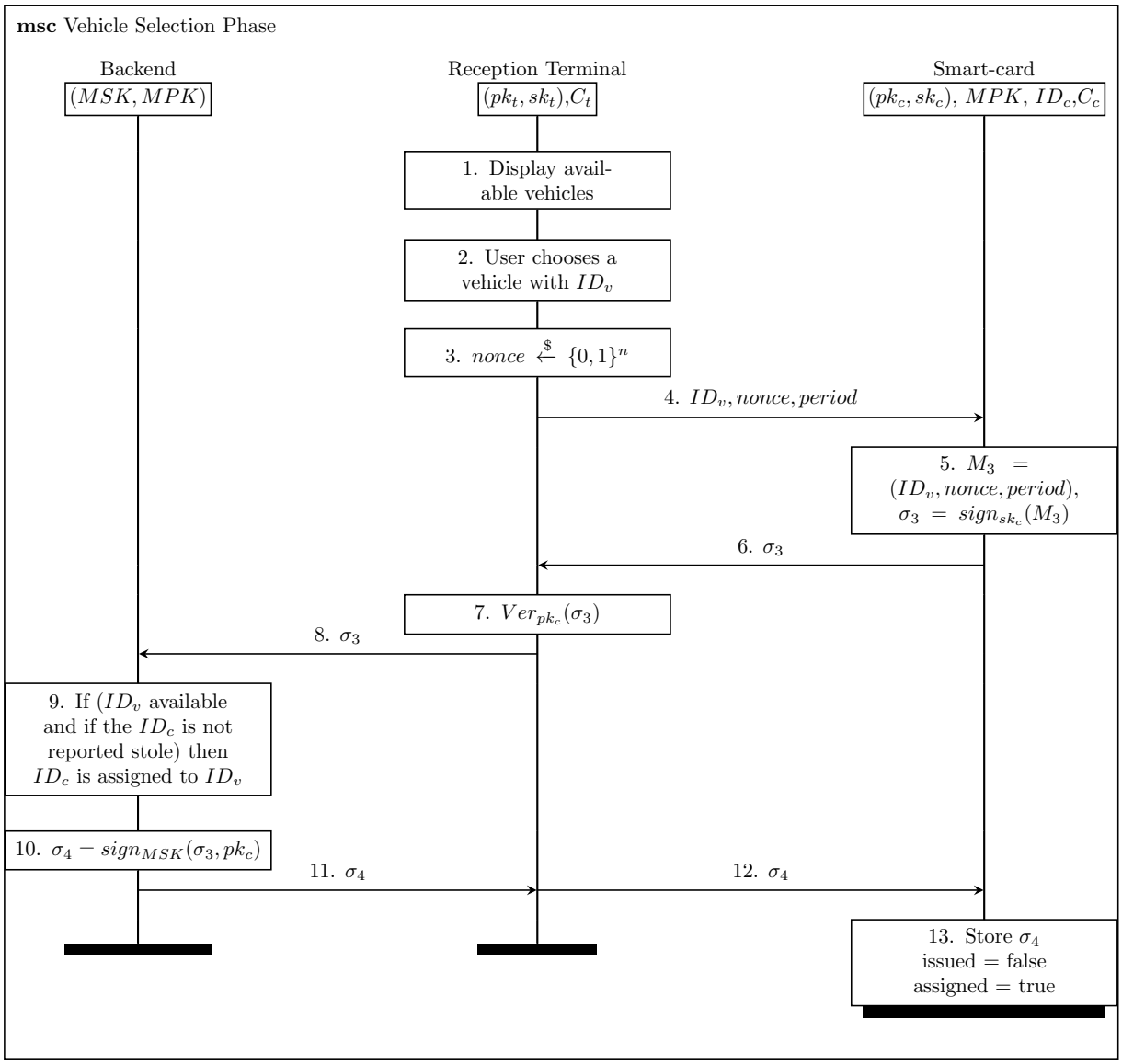


Figure 5: Vehicle selection and assignment phase

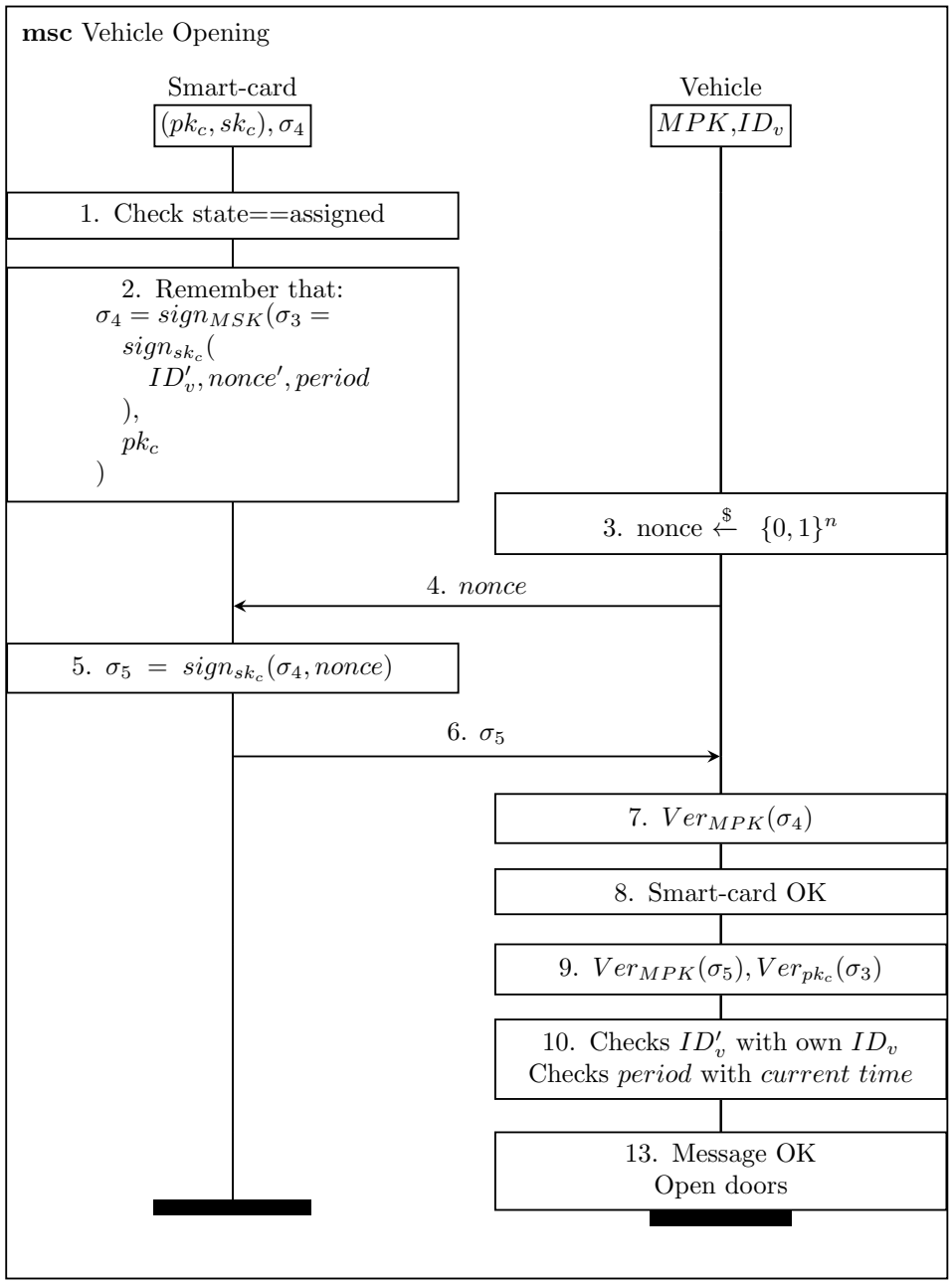


Figure 6: Vehicle opening protocol